Procedimiento de Verificación de Órdenes e Instrucciones Financieras

ISO/IEC 27001:2022 — Anexo A 5.3, A 5.12, A 5.14, A 5.17, A 5.33, A 8.5; riesgos RSC-006, RSC-010, RSC-014, RSC-019

Código de documento	SGSI-DOC-007	**Versión**	1.7
Estado	Borrador	**Clasificación**	Interna
Propietario	Responsable financiero — Atalaya GP SL	**Autor**	El consultor (externo)
Fecha de emisión	09/06/2026	**Fecha de aprobación**	Pendiente
Aprobado por	Pendiente conforme a DOC-002 §4	**Registro de aprobación**	Sin acta de aprobación de esta revisión. No acredita implantación ni firma contractual.

Historial de versiones

Versión	Fecha	Autor	Descripción del cambio
0.1	09/06/2026	El consultor	Emisión inicial
1.0	03/07/2026	Comité de Seguridad Convergente	Aprobación del documento
1.1	24/07/2026	El consultor	Alta de §6 (efectivo y valores, reglas E1-E5) para tratar RSC-019.
1.1	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.1.
1.2	24/07/2026	El consultor	Retirada de la narración de versiones del cuerpo (§6); límite entre R1-R6 y E1-E5 como norma vigente.
1.2	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.2.
1.3	24/07/2026	El consultor	Reformulación de la regla E5 (comprobación legal sin umbral). Ver decisiones.md §6.
1.3	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.3.
1.4	20/08/2026	El consultor	Recorte del historial de versiones a una línea por entrada, con referencia a decisiones.md donde procede. Sin cambios de fondo.
1.4	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.4.
1.5	20/08/2026	El consultor	Alta del diagrama de flujo de verificación de órdenes (Figura 1, §2).
1.5	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.5.
1.6	20/09/2026	Autor del caso	Revisión de coherencia de septiembre. Deltas y verificación en

Versión	Fecha	Autor	Descripción del cambio
			docs/fase1-iso27001/correcciones_2026-09.md. Sin cambios en la fecha de corte.
1.7	27/09/2026	Autor del caso	Revisión por dominios aplicables y alcance de controles. Corte 24/07/2026 conservado. Aprobación pendiente. Deltas: revisión 2026-09-27.

1. Objeto y amenaza que trata

Define cómo se emiten, verifican y ejecutan las órdenes con efecto de disposición patrimonial. Trata cuatro cadenas del registro de riesgos: la suplantación de un asesor o proveedor para desviar una transferencia (RSC-006), la suplantación del principal ante la banca —incluida la suplantación de voz sintética, hoy trivial contra una persona con cientos de horas de voz pública— (RSC-010) el abuso o coacción de la identidad digital delegada del principal (RSC-014) y el transporte y entrega de efectivo y valores en mano sin protocolo (RSC-019), que la sección 6 trata por separado porque no viaja por ningún canal verificable.

Premisa de diseño: en esta organización el principal no usa medios digitales y su identidad la opera su asistente personal. El procedimiento no finge que esto no es así; lo asume y lo compensa.

2. Reglas de verificación

Regla	Contenido
R1 — Doble canal siempre	Toda orden de disposición ≥ 10.000 € y todo cambio de datos de beneficiario, sin umbral, se verifica por un canal distinto de aquel por el que llegó, contra un contacto pre-registrado. Un email se verifica por llamada al número de la ficha de contactos verificados, nunca al que figure en el propio email o en su firma.
R2 — La voz no verifica	La voz no es factor de verificación para ninguna orden. Una llamada del principal, de un familiar o de un asesor conocido no exime del doble canal: la persona que llama puede no ser quien suena. Las entidades bancarias son informadas por escrito de que Atalaya no reconoce órdenes verificadas solo por voz.
R3 — Cuatro ojos	Las órdenes ≥50.000 € requieren dos personas distintas: prepara la asistente personal o el responsable financiero y valida la otra persona o Dirección General. A partir de ese umbral, la orden se confirma presencialmente con el solicitante antes de ejecutarse (C-059); una videollamada no sustituye esa confirmación. Para órdenes del principal se aplica además §4.
R4 — Cambio de beneficiario = alto riesgo	Todo cambio de cuenta de destino de un pago recurrente (asesores, proveedores, nóminas) se trata como intento de fraude hasta verificación en contrario: verificación R1 obligatoria más confirmación con una segunda persona de la entidad receptora.
R5 — Freno de emergencia	Urgencia, presión y confidencialidad exigida por el solicitante son indicadores de fraude, no motivos para saltarse el procedimiento. Cualquier interviniente puede detener una orden sin autorización previa y sin consecuencias; la orden detenida escala a la Dirección General y se anota en el cuaderno único de indicios (SGSI-DOC-009 §5), con independencia de que resultara legítima: el patrón de intentos importa aunque cada intento se explique.
R6 — Registro íntegro	Cada orden queda registrada con: solicitante, canal de entrada, verificaciones realizadas (quién, cuándo, por qué canal), validadores e importe. El registro lo revisa mensualmente la Dirección General.

Flujo actualizado: docs/fase1-iso27001/flujo_verificacion_ordenes.md (Mermaid). Esta revisión retira la figura anterior para evitar que contradiga la confirmación presencial de R3/C-059.

3. La ficha de contactos verificados

Existe una única lista de contactos de verificación (personas y números de asesores, banca y proveedores recurrentes), clasificada como Restringida, custodiada por el responsable financiero y contrastada en su creación por dos canales independientes. Los cambios en la ficha siguen la regla R4. La existencia misma de esta lista no se comunica a terceros.

4. Órdenes del principal

Las órdenes del principal se formalizan por escrito por su asistente y se confirman presencialmente o mediante videollamada iniciada por Atalaya a su dispositivo registrado. A partir de 50.000 €, la confirmación es obligatoriamente presencial y valida además Dirección General. No se acepta una llamada entrante como confirmación. El circuito reforzado se aplica a todas sus órdenes, sin umbral mínimo, y deja registro de cada interviniente.

5. Excepciones

Las órdenes fraccionadas para eludir umbrales se detectan en la revisión mensual y se tratan como incidente. La vía de urgencia exige validación conjunta y simultánea de Dirección General y responsable financiero, documentada en 24 horas; no exime de la confirmación presencial exigible ni permite ejecutar una orden sin verificar su legitimidad.

6. Disposiciones en efectivo y movimiento físico de valores

Las reglas R1 a R6 presuponen que toda orden de disposición viaja por un canal —correo, llamada, sistema bancario— sobre el que puede aplicarse una verificación cruzada. Esa premisa no cubre toda la operativa real de la organización. Una parte real de las disposiciones de esta organización no viaja por ningún canal: se ejecuta entregando efectivo o valores en mano, decidida por el principal y materializada por él mismo o por una persona de su confianza (RSC-019). Sobre esa práctica no operan las reglas R1 a R6, y por eso esta sección establece un conjunto propio.

El riesgo tiene tres caras y ninguna es el importe en sí. Primera: una sola persona decide, ejecuta y custodia, sin que exista el cuatro ojos de R3. Segunda: el portador se convierte en objetivo, y quien conozca el calendario del movimiento conoce dónde y cuándo estará esa persona con ese contenido —por eso el control primario aquí es de clasificación, no de transporte—. Tercera: no queda rastro reconstruible, de modo que una pérdida o un desvío no son investigables a posteriori, exactamente como en el cuasi-incidente fundacional la detección no era auditable.

Regla	Contenido
E1 — Doble validación previa	Toda disposición en efectivo o entrega física de valores ≥ 10.000 € se valida antes de su ejecución por dos personas conforme a R3, con independencia de quién la haya decidido. La validación es previa y por escrito: una entrega ya ejecutada no se valida, se registra como incidente.
E2 — La existencia del movimiento es Restringida	El hecho de que vaya a producirse un movimiento, su fecha y su importe son información Restringida (SGSI-DOC-002, sección 5), con difusión limitada a quienes intervienen. Esta regla protege más que cualquier medida de transporte: el conocimiento anticipado del movimiento es el habilitador de la acción hostil, no el movimiento en sí.
E3 — Trazabilidad en origen y destino	Todo movimiento genera registro firmado en origen y en destino, con importe, concepto, portador e intervinientes,

Regla	Contenido
	conciliado en las 24 horas siguientes por una persona distinta del portador. El registro se integra en la revisión mensual de R6.
E4 — Portador y ruta	El portador rota y no es sistemáticamente la misma persona. Ruta y horario varían entre movimientos. Por encima de 50.000 € o cuando el jefe de seguridad lo determine por el destino, el movimiento se acompaña. El principal no actúa como portador en movimientos previstos: su presencia convierte una operación logística en un objetivo señalado.
E5 — Límites legales	Toda disposición en efectivo o entrega física de valores respeta los límites legales de pago en efectivo y las obligaciones de declaración de movimientos aplicables (SGSI-REG-005, L-09). La comprobación del encaje legal es previa a toda disposición, con independencia del importe y del umbral que active E1: el responsable financiero verifica el límite legal aplicable según la condición del perceptor — mil euros cuando intervenga un empresario o profesional— y las obligaciones de declaración. El umbral de diez mil euros de E1 fija cuándo se exige doble validación, no cuándo se comprueba la legalidad; confundir ambas cosas dejaría sin control la franja intermedia, que es justamente donde el límite legal muerde. Una operación sin encaje legal no se ejecuta, con independencia de quién la ordene y de su importe.

Aplicación de DOC-004 §6 revisado: E1, E2 y E3 son medidas organizativas; E4 aporta protección física. E3 se documenta en papel (C-039), sin acreditar DIGITAL. RSC-019 se analiza como físico por su cadena de transporte y entrega; no se exige crear un dominio digital. HD-09 conserva separadamente el pendiente de RSC-020. La traza de conservación sigue en A.5.33; no se reactiva A.8.15 para C-039.

Anexo A. Trazabilidad

Sección	Control ISO/IEC 27001:2022 (Anexo A)
2 — Reglas R1 a R6	5.14, 8.5; 5.17 (información de autenticación)
3 — Contactos verificados	5.14, 5.12
4 — Órdenes del principal	5.3 (segregación), 5.17
6 — Disposiciones en efectivo	5.3, 5.12, 5.33, 7.9, 7.10, 8.5 (RSC-019)

Precisión de trazabilidad 27/09/2026. C-059 (RSC-006) y C-065 (RSC-010) solo computan en el supuesto ≥50.000 €; se declaran CONDICIONADO. Su existencia no prueba un componente físico del ataque. C-061 y C-062 son ORGANIZATIVO: una palabra de control y una instrucción firmada al banco no acreditan por sí solas un mecanismo técnico. C-016/C-019 conservan pendiente justificar su cobertura digital. Se mantiene el procedimiento y RAT T-06, sin ampliar datos ni finalidades.